

MICROSOFT 365

Roles administrativos

Modelo de permisos, portales de administración, roles integrados y mejores prácticas de seguridad

Guía técnica para administradores de TI



Contenido de la sesión

01 Modelo de permisos

Roles, ámbitos y asignaciones basados en Azure RBAC.

02 Tipos y categorías

Roles globales, de servicio y de característica; administradores, lectores y aplicaciones.

03 Portales de administración

Microsoft 365, Entra ID, Defender y Purview.

04 Roles más utilizados

Del Global Administrator al Teams Administrator.

05 Mejores prácticas

Mínimo privilegio, PIM, MFA y revisiones de acceso.

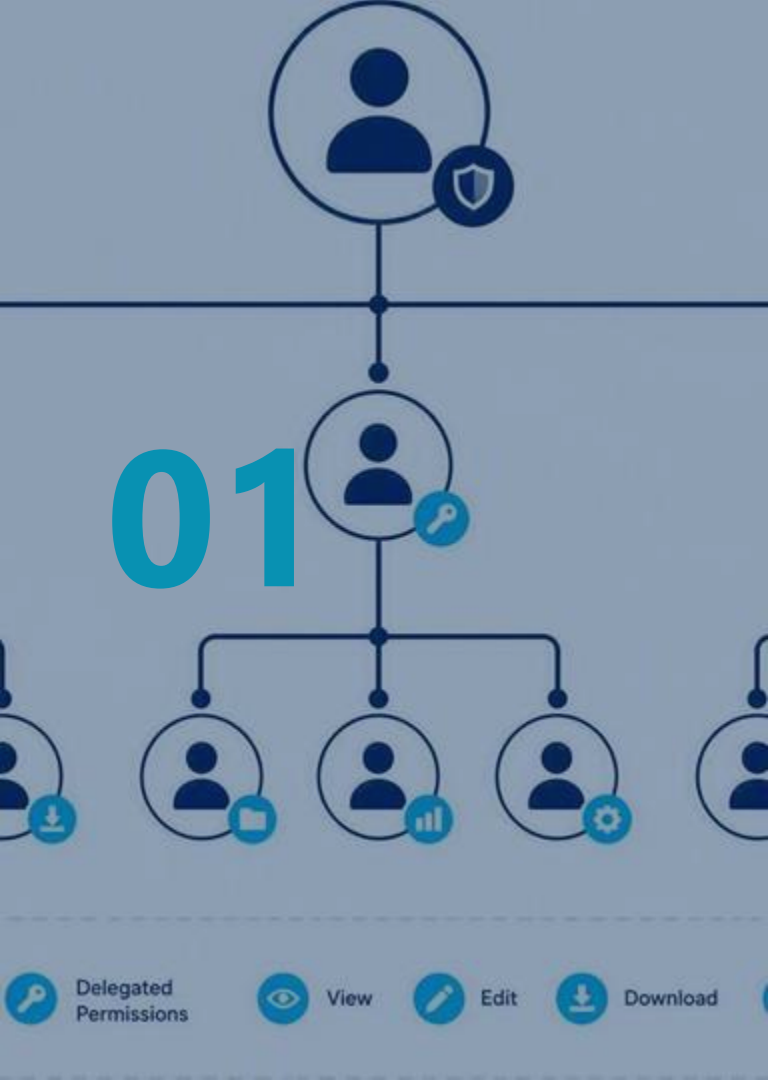
06 Asignación de roles

Admin center y Microsoft Graph PowerShell.

¿Qué son los roles administrativos?

- Microsoft 365 incluye roles administrativos que se asignan a usuarios según funciones empresariales comunes.
- Cada rol otorga permisos para realizar tareas específicas dentro de los centros de administración.
- El modelo de permisos controla quién puede hacer qué y sobre qué recursos mediante roles, grupos de roles, ámbitos, asignaciones, unidades administrativas y PIM.
- Alcanza servicios como Exchange Online, SharePoint Online, Teams y Microsoft Entra ID, e incluye la delegación a partners.
- Los grupos de roles permiten asignar uno o más roles a un grupo: sus miembros heredan los permisos.
- Las unidades administrativas y PIM limitan el alcance y habilitan acceso just-in-time y just-enough-access.

01



Modelo de permisos de Microsoft 365

Roles, ámbitos y asignaciones sobre Azure RBAC

Roles: conjuntos de permisos

Roles integrados (built-in)

Predefinidos, cubren los escenarios más comunes. Más de 30 roles integrados en Microsoft 365, como Exchange Administrator, SharePoint Administrator, Teams Administrator y Security Reader.

Roles personalizados (custom)

Se crean para necesidades específicas, partiendo de un rol existente o desde cero, con permisos granulares sobre recursos o acciones concretas.

Ámbitos y asignaciones

Directory scopes

Basados en la estructura organizativa: limitan el rol a grupos, sitios, equipos, ubicaciones, departamentos o cargos.

Management scopes

Basados en el servicio o aplicación: Exchange Online, SharePoint Online o Teams, o condiciones como tipos de buzón o colecciones de sitios.

Direct assignments

El rol se asigna directamente a un usuario o a un grupo.

Indirect assignments

Los permisos se conceden mediante membresías o reglas, de forma dinámica según los cambios de membresía. Admiten roles personalizados y ámbitos de administración.

Tipos y categorías de roles

Global roles

Permisos de alto nivel en todos los servicios: Global Administrator, Global Reader, Power Platform Administrator.

Service-specific roles

Administran un servicio concreto: Exchange Online, SharePoint Online, Teams u OneDrive.

Feature-specific roles

Administran una característica: seguridad, cumplimiento o administración de dispositivos.

Administrator roles

Gestionan usuarios, dispositivos, licencias, políticas, configuraciones y reportes.

Reader roles

Consultan información y reportes sin realizar modificaciones.

Application roles

Dan acceso a aplicaciones como Power BI, Power Apps o Power Automate, sin capacidades administrativas.



Overview Last 30 days Recent Activity



2,531 Actions 6,782 View all activity



Portales de administración

Dónde vive cada conjunto de roles

Portales y sus roles

Servicio o aplicación	Roles	Ubicación
Microsoft 365	Roles integrados y personalizados	Microsoft 365 admin center
Microsoft Entra ID	Roles de gobernanza de datos	Microsoft Entra ID portal
Microsoft Defender XDR	Roles de seguridad	Microsoft Defender portal
Microsoft Purview	Roles de catálogo de datos	Microsoft Purview portal

Nota: Azure Active Directory (Azure AD) ahora se denomina Microsoft Entra ID.

Microsoft 365 admin center

- Es el principal lugar para administrar roles integrados y personalizados de gran parte de la plataforma.
- Permite administrar roles de Microsoft Entra, Exchange e Intune, y crear role groups (grupos asignables a roles) cuyos miembros heredan los roles.
- Usuarios y grupos: creación y administración de cuentas, grupos y asignación de roles y permisos.
- Azure RBAC: asignación de roles predefinidos como Global Administrator, User Management Administrator, Exchange Administrator y SharePoint Administrator.
- Permisos específicos de servicios: Exchange Online, SharePoint Online, OneDrive y Teams.
- Permisos de aplicaciones: integraciones y consentimiento para aplicaciones externas que acceden a datos de Microsoft 365.

Alcance de los roles y sus identidades

Microsoft Entra

Roles con alcance sobre todo el tenant. Se asignan a usuarios y a grupos asignables a roles.

Exchange

Roles de workload. Se asignan a usuarios y grupos habilitados para correo. Los grupos de roles se crean en Exchange Online, pero no se asignan desde Microsoft 365.

Intune y Purview

Roles de workload. Las asignaciones de Intune se realizan sobre grupos de seguridad.

Roles generales frente a roles del servicio

Exchange Administrator

Administra buzones, grupos y políticas de Exchange Online, pero no necesariamente tareas avanzadas como conectores, reglas de transporte y flujo de correo: requieren roles más granulares del Exchange admin center.

Security Administrator

Otorga permisos amplios sobre los servicios de seguridad, pero no todos los del portal Microsoft Defender. Incidentes, investigaciones o roles RBAC personalizados pueden requerir roles propios de Defender.

Microsoft Entra ID portal

- Solución de Identity as a Service (IaaS) para administrar identidad y acceso: identidades, políticas de acceso y gobernanza.
- Roles derivados de Microsoft 365, como Identity Administrator e Identity Reader, y roles propios, como Identity Governance Administrator y Entitlement Management Administrator.
- Conditional Access: políticas de acceso basadas en ubicación, dispositivo y riesgo.
- Risk-based authentication: evaluación del riesgo según comportamiento y contexto.
- Identity insights and monitoring: visibilidad sobre identidades, inicios de sesión y uso de licencias.
- Passwordless authentication y data residency and security.

Microsoft Defender portal

- Consola centralizada para protección, detección, investigación y respuesta frente a amenazas: incidentes, investigaciones y acciones de seguridad.
- Roles derivados de Microsoft 365, como Security Administrator y Security Reader, y propios, como Incident Responder y Threat Hunter.
- Threat investigation: investigación y respuesta ante amenazas.
- Incident management: seguimiento, asignación y resolución de incidentes.
- Advanced hunting: consultas con Kusto Query Language sobre amenazas e indicadores de compromiso.
- Threat analytics e integración con Defender for Endpoint, Defender for Office 365 y Microsoft Cloud App Security.

Microsoft Purview portal

- Centro para administrar requisitos regulatorios y de cumplimiento, riesgos y protección de datos sensibles.
- Sus roles son un subconjunto de los de Microsoft Entra: derivados como Compliance Administrator y Compliance Reader, y propios como Data Source Administrator y Data Asset Curator.
- Compliance management: políticas de cumplimiento.
- Data protection: DLP, information barriers, sensitivity labels y gobernanza de datos.
- Risk assessment and insights: Compliance Score, análisis y recomendaciones.
- E-discovery y legal hold, compliance reporting and auditing, y colaboración y capacitación.



03

Roles administrativos más utilizados

Qué habilita cada rol integrado

Administrar los roles con cuidado

- Los roles integrados de la suscripción se asignan desde el Microsoft 365 admin center y corresponden a funciones empresariales comunes.
- Microsoft 365 administra roles de Microsoft Entra e Intune, aunque son solo un subconjunto de los disponibles en sus centros de administración.
- Deben asignarse cuidadosamente: dan acceso a datos y configuraciones sensibles.
- Para administrar permisos se requiere ser Global Administrator o miembro del grupo de roles Organization Management.
- El rol Role Management permite ver, crear y modificar grupos de roles en Microsoft Defender y está asignado de forma predeterminada a Organization Management.
- Exchange Online usa un modelo similar a Azure RBAC más permisos individuales de buzón; SharePoint Online usa grupos de seguridad y niveles de permisos.

Recomendaciones de seguridad al asignar roles

Recomendación	Motivo
Mantener entre 2 y 4 Global Administrators	Se necesitan al menos dos para situaciones como el bloqueo de cuentas, pero un exceso aumenta el riesgo de seguridad.
Asignar el rol menos permisivo	Cada administrador debe recibir únicamente los permisos necesarios para realizar su trabajo.
Requerir MFA para administradores	Protege las cuentas incluso si la contraseña queda comprometida.

Los roles se consultan en Role assignments: la pestaña Permissions muestra las tareas permitidas y Assigned admins permite agregar usuarios.

Roles clave de la organización

Global Administrator

Acceso a casi todas las funciones administrativas de Entra ID y de los servicios que usan sus identidades: Defender, Purview, Exchange y SharePoint. Restablece contraseñas, administra dominios, desbloquea a otros Global Administrators y eleva su acceso a Azure. No puede eliminar su propia asignación.

Global Reader

Alternativa de solo lectura: lee configuraciones e información administrativa para planificación, auditorías e investigaciones. Se combina con roles limitados como Exchange Administrator y funciona en Microsoft 365, Exchange, SharePoint, Teams, Defender, Purview, Azure y Device Management.

Facturación, cumplimiento y correo

Billing Administrator

Compras, suscripciones, solicitudes de servicio, estado de los servicios, facturación y tickets de soporte en el Microsoft Entra admin center.

Compliance Administrator

Cumplimiento normativo, casos de eDiscovery, políticas de gobernanza y cumplimiento, alertas, investigaciones legales y Data Subject Requests.

Exchange Administrator

Buzones, Microsoft 365 Groups, flujo de mensajes, retención, uso compartido, delegados Send As y Send on Behalf y filtros antispam. Se recomienda añadir Service Administrator.

Usuarios, grupos, soporte y licencias

Groups Administrator

Crea, edita, elimina y restaura Microsoft 365 Groups; administra políticas de creación, expiración y nomenclatura, y grupos de seguridad de Entra.

Helpdesk Administrator

Restablece contraseñas, fuerza el cierre de sesión, invalida refresh tokens, administra solicitudes de soporte y supervisa el estado de los servicios.

User Administrator

Agrega usuarios y grupos, asigna licencias y administra propiedades, vistas, políticas de contraseñas, restauración de usuarios y claves FIDO.

License Administrator

Consulta y actualiza asignaciones de licencias, licencias basadas en grupos y ubicación de uso. No compra ni administra suscripciones.

Password Administrator

Restablece contraseñas de usuarios no administradores y de otros Password Administrators, con capacidades limitadas.

Message Center Reader

Supervisa notificaciones y actualizaciones, recibe resúmenes semanales y comparte publicaciones. No administra tickets de soporte.

Servicios, seguridad y reportes

Security Administrator

Políticas de seguridad, analítica, amenazas y alertas, roles, machine groups, remediación automatizada y protección de contraseñas. Cubre Defender, Entra ID Protection y Purview.

SharePoint Administrator

Sitios, colecciones de sitios, configuración global, Microsoft 365 Groups, perfiles de usuario, conexiones BCS, búsqueda y configuraciones híbridas.

Teams Administrator

Telefonía, mensajería, reuniones, equipos, Microsoft 365 Groups, conference bridges, federation y solución de problemas de comunicación.

Office Apps Administrator

Configuración y políticas cloud de las aplicaciones de Microsoft 365, descargas de autoservicio y contenido What's New.

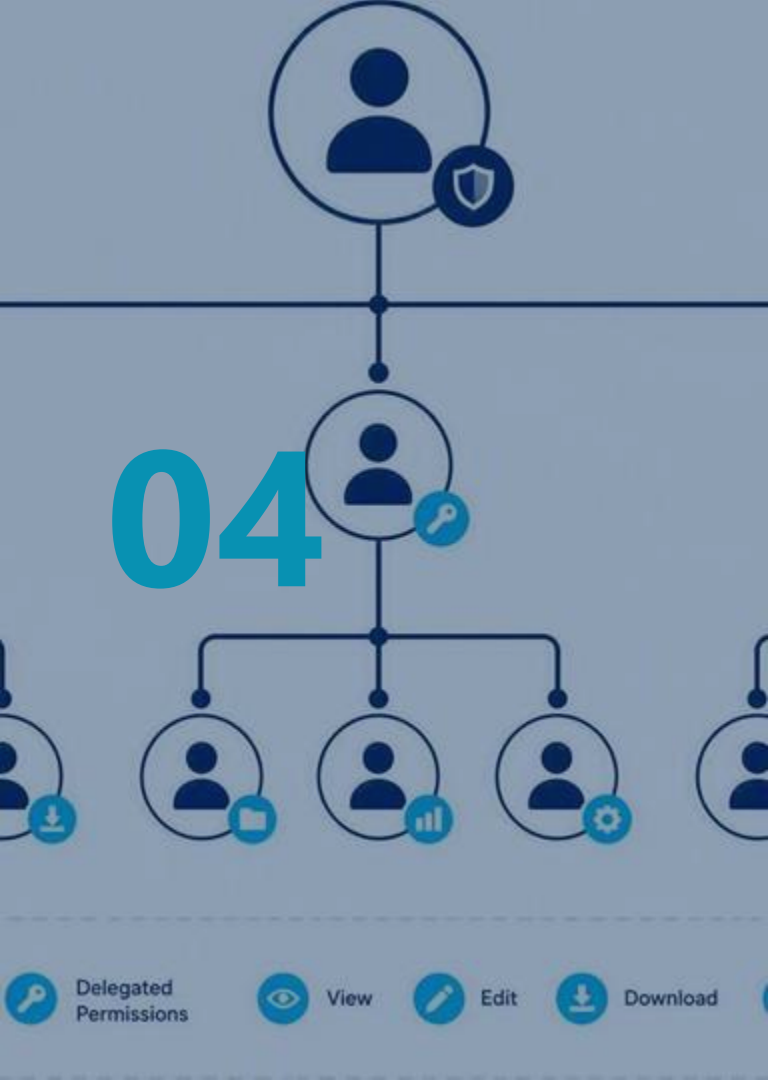
Power Platform Administrator

Funciones administrativas de Power Apps, flows, políticas de prevención de pérdida de datos, solicitudes de servicio y estado de los servicios.

Reports Reader / Service Support

Reports Reader consulta uso, dashboards, actividad y logs. Service Support Administrator gestiona solicitudes de soporte y el Message Center.

04



Mejores prácticas de configuración

Mínimo privilegio, PIM, MFA y revisiones

Siete prácticas recomendadas (1-4)

1. Mínimo privilegio

Otorgar exactamente los permisos necesarios considerando permisos, ámbito y período de tiempo. Entra RBAC admite más de 65 roles integrados; si ninguno encaja, se crean roles personalizados.

2. PIM para acceso just-in-time

El usuario es miembro elegible y activa el rol por un tiempo limitado. PIM retira el acceso al finalizar, puede exigir aprobación y notificar activaciones y altas en roles muy privilegiados.

3. MFA en todas las cuentas admin

Configurable desde PIM o Conditional Access. Según los estudios mencionados, MFA reduce en un 99,9 % la probabilidad de que las cuentas sean comprometidas.

4. Revisiones periódicas de acceso

Las Access Reviews verifican que solo las personas adecuadas conserven permisos: una cuenta puede ser comprometida y los usuarios acumulan permisos al cambiar de equipo.

Siete prácticas recomendadas (5-7)

5. Menos de cinco Global Administrators

Reduce la superficie de ataque. Todas las cuentas deben protegerse con MFA y conviene mantener dos cuentas break glass permanentes que no dependan del mismo mecanismo de MFA.

6. Grupos y delegación

Asignar roles a grupos de Microsoft Entra cuando existe gobernanza externa basada en grupos. Los grupos asignables a roles se administran con PIM; su propietario decide indirectamente quién recibe el rol.

7. Cuentas cloud-native

Evitar cuentas sincronizadas desde entornos on-premises: si una se compromete, también podrían comprometerse los recursos de Microsoft Entra.



Overview Last 30 days Recent Activity



- User admin@company.com logged in
- Role "Editor" updated
- Permission policy changed
- New device added
- User john.doe@company.com logged out

2,531 Actions 6,782 View all activity



Asignación de roles

Admin center y Microsoft Graph PowerShell

Asignar roles desde el Microsoft 365 admin center

- Los roles no son mutuamente excluyentes: un usuario puede tener Exchange Administrator, SharePoint Administrator y User Management Administrator a la vez.
- Se basan en grupos de Microsoft Entra que no aparecen en el Entra admin center, pero se asignan desde Microsoft 365 o PowerShell. Se requiere una cuenta Global Administrator.
- Ir a Users > Active Users y seleccionar el usuario.
- En Roles, seleccionar Edit.
- Elegir User (sin acceso administrativo), Global administrator o Customized administrator para seleccionar roles concretos.
- Indicar un Alternative email address para notificaciones importantes, incluido el restablecimiento de contraseña administrativa, y seleccionar Save.

Consultar usuarios y roles con PowerShell

Conectar y listar usuarios (se necesita el Object ID del usuario y del rol)

```
Install-Module Microsoft.Graph -Scope CurrentUser  
Import-Module Microsoft.Graph.Identity.DirectoryManagement  
Connect-MgGraph -Scopes 'User.Read.All', 'RoleManagement.ReadWrite.Directory'  
Get-MgUser -All | Format-List ID, DisplayName, Mail, UserPrincipalName
```

Consultar los roles activados (solo se muestran los roles activados)

```
Get-MgDirectoryRole | Format-List
```

Activar y asignar un rol

Asignar un rol ya activado a un usuario

```
$UserObjectId = @{ "odata.id" = "https://graph.microsoft.com/v1.0/directoryObjects/e4e2b110-8d4f-434f-a990-7cd63e23aed6" }  
New-MgDirectoryRoleMemberByRef -DirectoryRoleId 'a2d10e79-df32-47fc-86ef-64d199860810' -BodyParameter  
$UserObjectId
```

Activar un rol mediante su template (por ejemplo, Helpdesk Administrator)

```
Get-MgDirectoryRoleTemplate -All | Format-List ID, DisplayName  
New-MgDirectoryRole -roleTemplateId '95e79109-95c0-4d8e-ae3-d01accf2d47b'  
Get-MgDirectoryRole | Format-List
```

Conceptos fundamentales

Roles, scopes y assignments

Los roles definen qué acciones pueden realizarse, los scopes limitan dónde se aplican y las asignaciones vinculan ambos con usuarios o grupos.

Role groups

Permiten asignar roles mediante grupos: sus miembros heredan los permisos y se centraliza la delegación.

Portales

El Microsoft 365 admin center administra los roles generales; Entra, Defender y Purview mantienen roles propios y más granulares.

Least privilege y PIM

Asignar solo los permisos necesarios, sobre el alcance necesario y durante el tiempo necesario, con acceso just-in-time.

MFA y Access Reviews

MFA protege las cuentas administrativas y las revisiones retiran los permisos que ya no son necesarios.

Global Administrator y cuentas cloud-native

Limitar Global Administrator a menos de cinco personas y preferir cuentas cloud-native para los roles de Microsoft Entra.

Gracias

Menor privilegio, acceso just-in-time y MFA: la base de una administración segura de Microsoft 365